Shavaughn Hamilton

Summarized Description of Audit Program Project:

- Designed a **cybersecurity audit program** for Oscorp using the **Three Lines of Defense Model**, ensuring periodic testing of cybersecurity controls.
- Defined **Line 1** responsibilities for self-auditing by the cybersecurity team to identify and report security gaps.
- Recommended **Line 2** establishment of an independent **Cybersecurity Auditor** to validate controls through log reviews, penetration test results, and compliance checks.
- Proposed **Line 3** integration of an external consulting firm to conduct **internal audits**, ensuring oversight and adherence to best security practices.
- Strengthened **governance, risk, and compliance (GRC) practices**, enhancing **firewall management, incident response, and regulatory compliance**.

Audit Program

By Shavaughn Hamilton

Chief Scientist Harry Osborn has managed to make a breakthrough with his new highly confidential medication.

Oscorp's CEO asked you to design a cyber security audit program to ensure that Oscorp's cyber security controls are tested on a periodic basis.

Oscorp currently has a small cyber security team that perform various technical activities such as detecting and responding to cyber security incidents and managing the firewalls.

They also have an internal audit function that conducts financial audits.

Problem:

As an external cyber security consultant, how would you design a cyber security audit program for Oscorp using the three lines of defence model?

Practical Assessment Answer: Audit Program

Line 1 as the cybersecurity team, aka the control owner, responsible for installing and maintaining and configuring firewall and security controls. Self-audit, self-reporting, tells management if firewall is working as expected.

Line 2 as independent individuals who work in a different team under different management to audit what line 1 does, asks line 1 what controls are implemented, gets evidence from line one line such as screen shots of logs, design diagrams, asks for pen test results, and makes sure controls are doing what they are supposed to do.

Line 3 – aka internal audit, audit what line 1 and line 2 does to see if controls are implemented and working well, makes sure line 2 has validated everything they requested.

All lines (1-3) are meant to be employees of the organization, even if the organization hires external auditors.

Following the three lines of defence model, you can propose the following:

- **Line 1**: The cyber security team can perform regular self-audits to ensure that they identify and documents any gaps that they discover.

- **Line 2**: As you've learned in the course, finding individuals who understand GRC and auditing is challenging. You propose that Oscorp hires a full time Cyber Security Auditor to perform Line 2 audits. Bonus points if they hire someone who completed this cyber security GRC Mastery training course!

- **Line 3 (Internal Audit):** Oscorp current internal audit team does not include anyone who can perform cyber security audits (because they're financial auditors). You can propose that Oscorp hires your firm as their internal auditors. Your consulting firm can create an internal audit program for Oscorp that focuses on testing cyber security controls.